

App Flow & UX Architecture Document

App Name: CloudGuard GRC[cite: 1]

Document Version: 1.0.0 (UI/UX Routing, Screen Matrix & Interaction States)

Target Stack: React.js, React Router v6, TailwindCSS, FastAPI REST API[cite: 1]

1. Complete Screen Architecture Matrix

Screen ID	Page / Screen Name	Route Path	Allowed User Roles
SCR-01	Login & Authentication Screen	/login	Public / All Users[cite: 1]
SCR-02	Registration & Account Setup	/register	Public / New Signups[cite: 1]
SCR-03	Global Security Dashboard	/dashboard	Super Admin, Admin, Analyst, Auditor, Viewer[cite: 1]
SCR-04	Cloud Account Onboarding Wizard	/accounts/onboard	Super Admin, Cloud Account Admin[cite: 1]
SCR-05	Cloud Account Inventory Table	/accounts	Super Admin, Cloud Account Admin, Analyst, Auditor[cite: 1]
SCR-06	Security Findings & Risks Grid	/findings	Super Admin, Admin, Analyst, Auditor[cite: 1]
SCR-07	Finding Detail & Remediation Drawer	/findings/:findingId	Super Admin, Admin, Analyst[cite: 1]
SCR-08	GRC Compliance Matrix & Reports	/compliance	Super Admin, Admin, Analyst, Auditor[cite: 1]
SCR-09	Settings, Notifications & Integrations	/settings	Super Admin, Admin[cite: 1]
SCR-10	Billing, Usage & Subscription Upgrade	/billing	Super Admin[cite: 1]

2. User Journeys

Journey 1: First-Time Onboarding & Initial Scan

1. User signs up at `/register` or logs in via Cognito/OAuth at `/login` [cite: 1].
2. System redirects user to `/dashboard`. Detecting zero accounts, an onboarding banner redirects to `/accounts/onboard` [cite: 1].
3. User generates an External ID on `SCR-04` and pastes the AWS Read-Only IAM Role ARN created in their AWS Console[cite: 1].
4. User clicks **"Verify & Connect Account"**. Backend tests `sts:AssumeRole` [cite: 1].
5. On validation success, system redirects to `/dashboard` and triggers an immediate background scan via SQS/Lambda worker[cite: 1].
6. Dashboard displays progress bar: *"Scan in Progress (S3, IAM, EC2)..."* followed by real-time population of findings[cite: 1].

Journey 2: Finding Triage & Code Remediation

1. Security Analyst lands on `/findings` and filters by `Severity: CRITICAL` and `Framework: CIS AWS` [cite: 1].
2. Analyst selects a row (e.g., *"S3 Bucket Publicly Accessible"*) opening the Detail Drawer (`SCR-07`) [cite: 1].
3. Drawer renders compliance impact (CIS 2.8, DPDPA Sec 8), affected resource ARN, and Terraform/CLI fix snippets[cite: 1].
4. Analyst clicks **"Copy Terraform Remediation"** to fix locally, or clicks **"Auto-Remediate"** (Pro/Enterprise tier trigger)[cite: 1].
5. Analyst clicks **"Mark as Resolved"** or **"Trigger Re-scan"**. Status updates dynamically[cite: 1].

Journey 3: Auditor Compliance Report Export

1. Auditor logs in with Read-Only credentials and navigates directly to `/compliance` [cite: 1].
2. Auditor selects the desired benchmark view (e.g., **DPDPA 2023** or **CIS AWS v1.2**) [cite: 1].
3. System displays pass/fail percentages across controls[cite: 1].
4. Auditor clicks **"Export Executive PDF"**. Modal displays formatting options[cite: 1].
5. System compiles audit report artifact asynchronously and triggers direct browser download[cite: 1].

3. Global Navigation & Layout Flow

The application enforces a standard SaaS Shell layout for authenticated routes (`SCR-03` through `SCR-10`):

- **Left Sidebar:** Navigation links to Dashboard, Accounts, Findings, Compliance, Settings, and Billing. Includes collapse/expand toggle and user tenant switcher.
- **Top App Bar:** Breadcrumbs trail, Global Account Filter dropdown, Trigger Instant Scan button, Alert Bell icon (Slack/Email logs), and User Profile avatar dropdown.
- **Main Content Canvas:** Dynamic route container rendering views with uniform padding and loading skeletons.

4. Screen-by-Screen Breakdown: UI Controls, Actions & States

SCR-03: Global Security Dashboard

- **Key UI Components:** ThreatScore gauge widget, Risk Distribution donut chart (Critical, High, Medium, Low), Compliance Scorecard cards (CIS, DPDPA, GDPR), 5 Most Recent Critical Findings table[cite: 1].
- **Button Actions:**
 - **"Run On-Demand Scan"**: Triggers POST to `/api/v1/scans/trigger`. Shows top-toast message: *"Scan queued for 3 connected accounts."* [cite: 1]
 - **"View All Findings"**: Redirects to `/findings` with pre-applied URL query parameters.

- **Success State** : Displays populated score widgets, operational status banner green.
- **Error State** : Banner top alert: *"Unable to fetch scan metadata. AWS API rate limit exceeded. Retrying in 60s."* [cite: 1]
- **Empty State** : Displays empty dashboard graphic with primary CTA: *"Connect Your First Cloud Account"* [cite: 1].

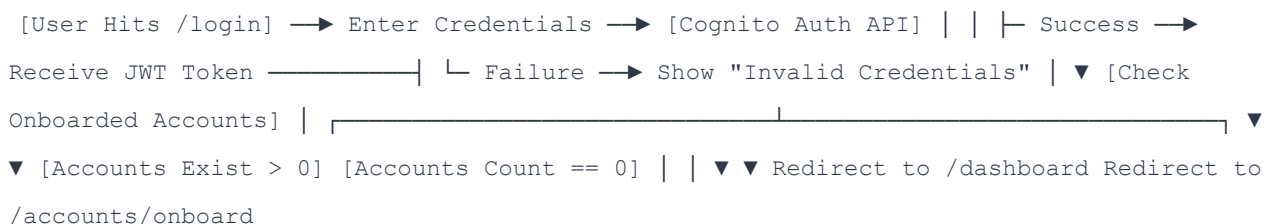
SCR-04: Cloud Account Onboarding Wizard

- **Key UI Components:** Step 1 (Select Provider: AWS/Azure/GCP), Step 2 (Copy External ID & CloudFormation Template Link), Step 3 (Role ARN Input Field & Alias)[cite: 1].
- **Button Actions:**
 - "Copy External ID" : Copies unique tenant string to clipboard.
 - "Launch CloudFormation Stack" : Opens AWS Console in new browser tab with pre-filled template parameters.
 - "Verify & Connect" : Triggers POST to `/api/v1/accounts/onboard`.
- **Success State** : Modal pop-up: *"AWS Account [Account-ID] Connected Successfully!"* with CTA to return to Dashboard.
- **Error State** : Red callout box below input: *"Access Denied: Unable to assume IAM Role. Verify trust policy contains External ID and sts:AssumeRole permissions."*[cite: 1]

SCR-06: Security Findings & Risks Grid

- **Key UI Components:** Search bar (filters by Resource Name/ID), Filter Chips (Severity, Cloud Service, Framework), Paginated Data Table with multi-select checkboxes[cite: 1].
- **Button Actions:**
 - "Export Selected (CSV) " : Downloads filtered dataset as CSV artifact.
 - "Batch Suppress" : Opens dialog to mark selected items as *"False Positive"* with justification text field[cite: 1].
 - Row Click: Slides open SCR-07 Finding Detail Drawer[cite: 1].
- **Empty State** : Green checkmark illustration with text: *"Zero misconfigurations detected! Your cloud accounts match all security policies."*[cite: 1]

5. Detailed Authentication & Onboarding Flow



6. Payment, Subscription & Upgrade Flow (Freemium to Paid Tier)

Free Tier vs. Pro/Enterprise Tier Matrix

Feature / Boundary	Free / Open-Source Tier	Pro / Enterprise Tier (Paid)
AWS Connected Accounts	Up to 1 Account[cite: 1]	Unlimited Multi-Account / Multi-Region[cite: 1]
Compliance Frameworks	CIS AWS Foundations Benchmark v1.2[cite: 1]	CIS, DPDPA 2023, GDPR, ISO 27001, SOC 2[cite: 1]

Feature / Boundary	Free / Open-Source Tier	Pro / Enterprise Tier (Paid)
Scan Frequency	Manual On-Demand Scans[cite: 1]	Automated Scheduled Daily/Hourly Scans[cite: 1]
Remediation Support	CLI & Terraform Manual Code Fixes[cite: 1]	1-Click Automated Lambda Auto-Remediation[cite: 1]

Upgrade Journey Architecture

1. User attempts to add a 2nd AWS Account or toggle **DPDPA Compliance Scan** on `SCR-08` [cite: 1].
2. System triggers feature-gate modal: *"Unlock Multi-Account Automation & DPDPA/GDPR Compliance Modules."*
3. User clicks **"Upgrade to Pro"** redirecting to `/billing` (`SCR-10`).
4. User selects Monthly or Annual plan and clicks **"Proceed to Checkout"**.
5. App redirects to Stripe Hosted Checkout Page via API session link.
6. On payment success, Stripe webhook updates tenant plan status in RDS PostgreSQL to `PRO_TIER` .
7. User is redirected back to `/billing?status=success` with updated feature toggles unlocked instantly.